



计算机系统与网络安全技术

Technology of Computer System and Network Security

黄可

huangke@uestc.edu.cn

计算机科学与工程学院（网络空间安全学院）

2024年5月22日5时33分

第五章 数据库与云安全

- 5.1 数据库安全需求
- 5.2 数据库管理系统
- 5.3 关系数据库
- 5.4 SQL 注入攻击
- 5.5 数据库访问控制
- 5.6 推理
- 5.7 数据库加密
- 5.8 数据中心安全

数据库安全

数据库安全
始终没有跟上
数据库应用
发展步伐
的原因是:

一些组织越来越依赖于云技术，将企业的部分或全部数据存储在云上

现代数据库管理系统 (DBMS) 的复杂程度与用于保护这些系统的安全技术是极为不匹配的。

数据库系统拥有非常成熟的交互协议，被称为结构化查询语言 (SQL)，它非常复杂。

大多数的企业环境是由多种数据库平台、企业平台和操作系统平台构成的一个异构环境。这在很大程度上增加了安全管理人员进行安全管理的难度。

一个组织或机构通常缺少专职的数据库安全管理人员，这样的后果是安全需求与安全保障能力的不匹配。

一些组织越来越依赖云技术，将企业的部分或全部数据存储在云上，这无疑增加了企业中负责安全的员工的负担。

第五章 数据库与云安全

- 5.1 数据库安全需求
- 5.2 数据库管理系统
- 5.3 关系数据库
- 5.4 SQL 注入攻击
- 5.5 数据库访问控制
- 5.6 推理
- 5.7 数据库加密
- 5.8 数据中心安全



数据库

- 是存储一个或多个应用所用数据的结构化数据集合。
- 数据库还包含数据项之间以及数据项组之间的关系。
- 可能包含敏感并且需要保护的数据
- 查询语言
 - 为用户和应用提供了访问数据库的统一接口

数据库管理系统(DBMS)

- 它是创建、维护数据库的程序套件。
- 多个用户和应用提供特定的查询服务

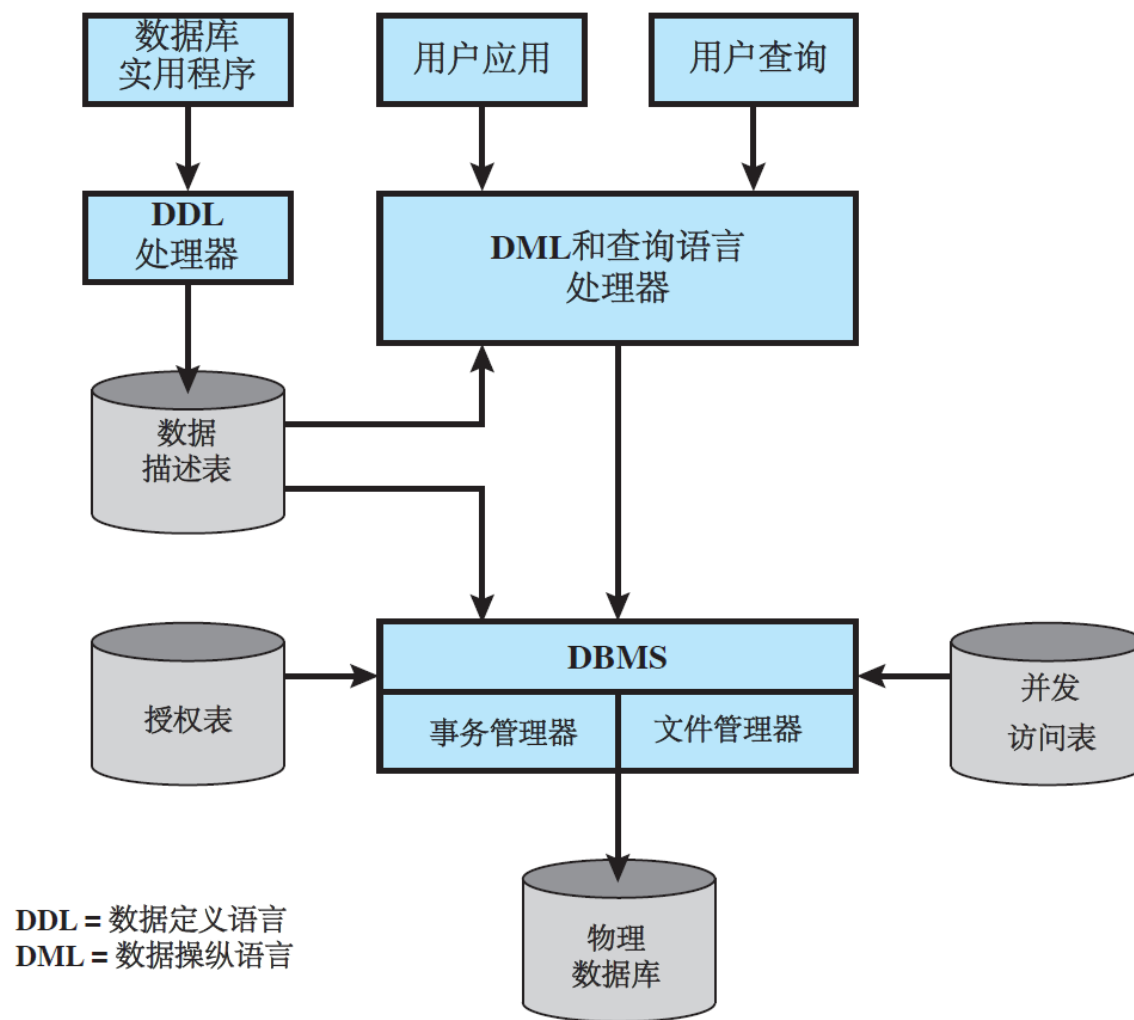


图 5.1 DBMS 体系结构

第五章 数据库与云安全

- 5.1 数据库安全需求
- 5.2 数据库管理系统
- 5.3 关系数据库
- 5.4 SQL 注入攻击
- 5.5 数据库访问控制
- 5.6 推理
- 5.7 数据库加密
- 5.8 数据中心安全



关系数据库

- 关系数据库的基本构件是数据表。数据表类似于电子表格，由行和列组成。
 - 每列包含某种类型的数据
 - 每行包含这些列的一组指定值。
 - 理想情况下，表中至少存在一列，其值是唯一的，作为指定项的标识符。
- 关系数据库的结构使得多个表通过在所有表中都出现的唯一标识符联系在一起。
- 用户和应用通过关系查询语言来访问数据库。
 - 查询语言允许用户请求满足一组给定条件的记录中的选定数据项。

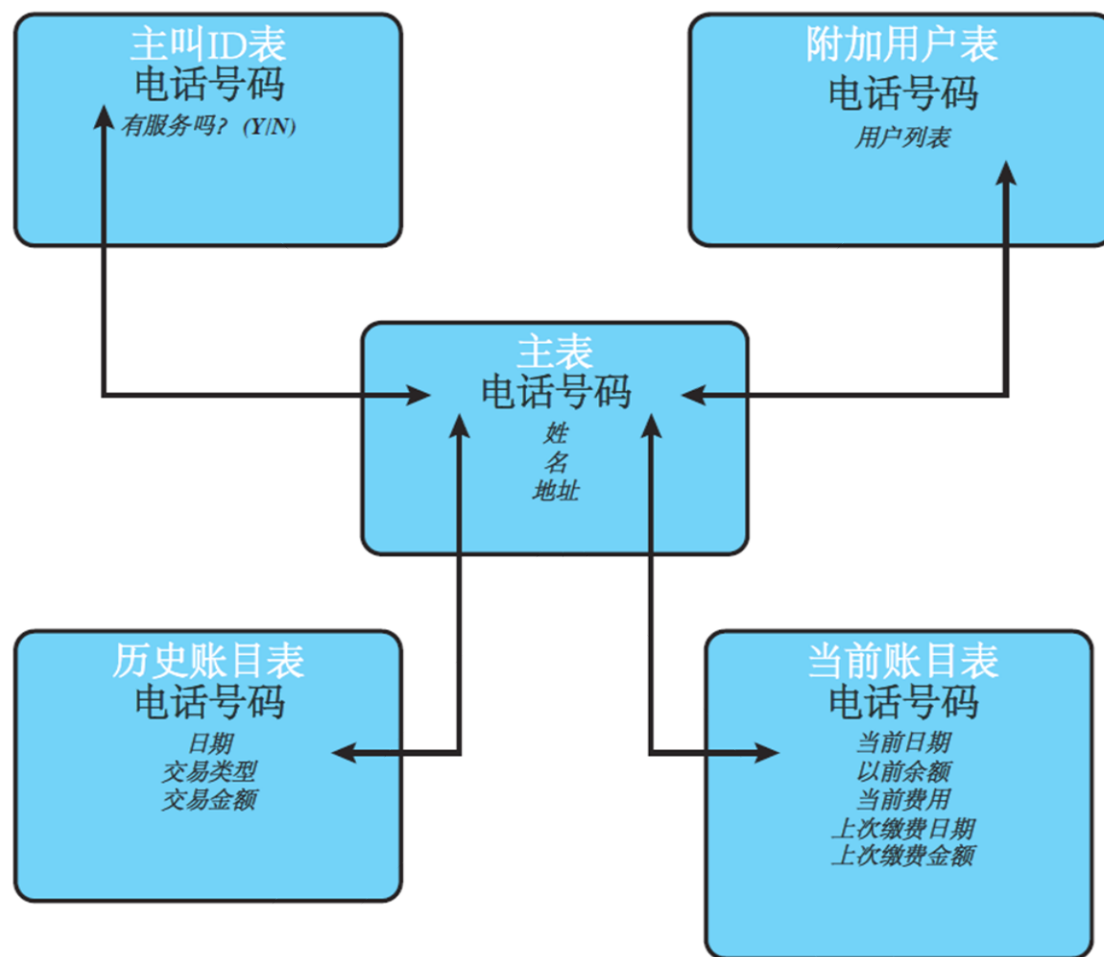


图 5.2 关系数据库模型举例。关系数据库通过指定的键将多个表关联起来，本例中，键是电话号码字段

关系数据库系统要素

- 关系
 - 表/文件
- 元组
 - 行/记录
- 属性
 - 列/字段

主键

- 用来唯一地标识表的一行
- 它由一个或多个列名组成

外键

- 在一个表中定义为主键的属性必须作为另一个表的属性出现

视图/虚表

- 视图是从一个或多个表中返回的选定行与列的查询结果。
- 视图经常用于安全目的。

表 5.1 关系数据库的基本术语

正式名	常用名	其他名字
关系	表	文件
元组	行	记录
属性	列	字段

		属性				
		A_1	• • •	A_j	• • •	A_M
记录	1	x_{11}	• • •	x_{1j}	• • •	x_{1M}
	•	•		•		•
	•	•		•		•
	•	•		•		•
	i	x_{i1}	• • •	x_{ij}	• • •	x_{iM}
	•	•		•		•
	•	•		•		•
	•	•		•		•
N		x_{N1}	• • •	x_{Nj}	• • •	x_{NM}

图 5.3 关系数据库的抽象模型

Department表			Employee表				
Did	Dname	Dacctno	Ename	Did	Salarycode	Eid	Ephone
4	human resources	528221	Robin	15	23	2345	6127092485
8	education	202035	Neil	13	12	5088	6127092246
9	accounts	709257	Jasmine	4	26	7712	6127099348
13	public relations	755827	Cody	15	22	9664	6127093148
15	services	223945	Holly	8	23	3054	6127092729
			Robin	8	24	2976	6127091945
			Smith	9	21	4490	6127099380

主键

外键

主键

a) 关系数据库中的两个表

Dname	Ename	Eid	Ephone
human resources	Jasmine	7712	6127099348
education	Holly	3054	6127092729
education	Robin	2976	6127091945
accounts	Smith	4490	6127099380
public relations	Neil	5088	6127092246
services	Robin	2345	6127092485
services	Cody	9664	6127093148

b) 从关系数据库导出的视图

图 5-4 关系数据库实例

结构化查询语言 (SQL)

- 是能够对关系数据库中的数据进行定义、操纵和查询的标准语言
- ANSI/ISO 制定的SQL标准有几个版本
- 都遵循相同的基本语法和语义

SQL 语句能够用于:

- 创建表
- 插入和删除表中的数据
- 创建视图
- 通过查询语句检索数据

第五章 数据库与云安全

- 5.1 数据库安全需求
- 5.2 数据库管理系统
- 5.3 关系数据库
- 5.4 SQL 注入攻击
- 5.5 数据库访问控制
- 5.6 推理
- 5.7 数据库加密
- 5.8 数据中心安全

SQL 注入攻击(SQLi)

- 是一类针对数据库的最普遍和最危险的基于网络的安全威胁。
- 一般而言，SQLi攻击利用的是Web应用程序页面的性质。
- 通过发送恶意的SQL命令到数据库服务器就可以发起SQLi攻击。
- 最常见的攻击目标是从数据库中批量提取数据。
- 根据环境的不同，还可以利用SQL注入来：
 - 修改或删除数据
 - 执行任意操作系统命令
 - 启动拒绝服务(DoS)攻击

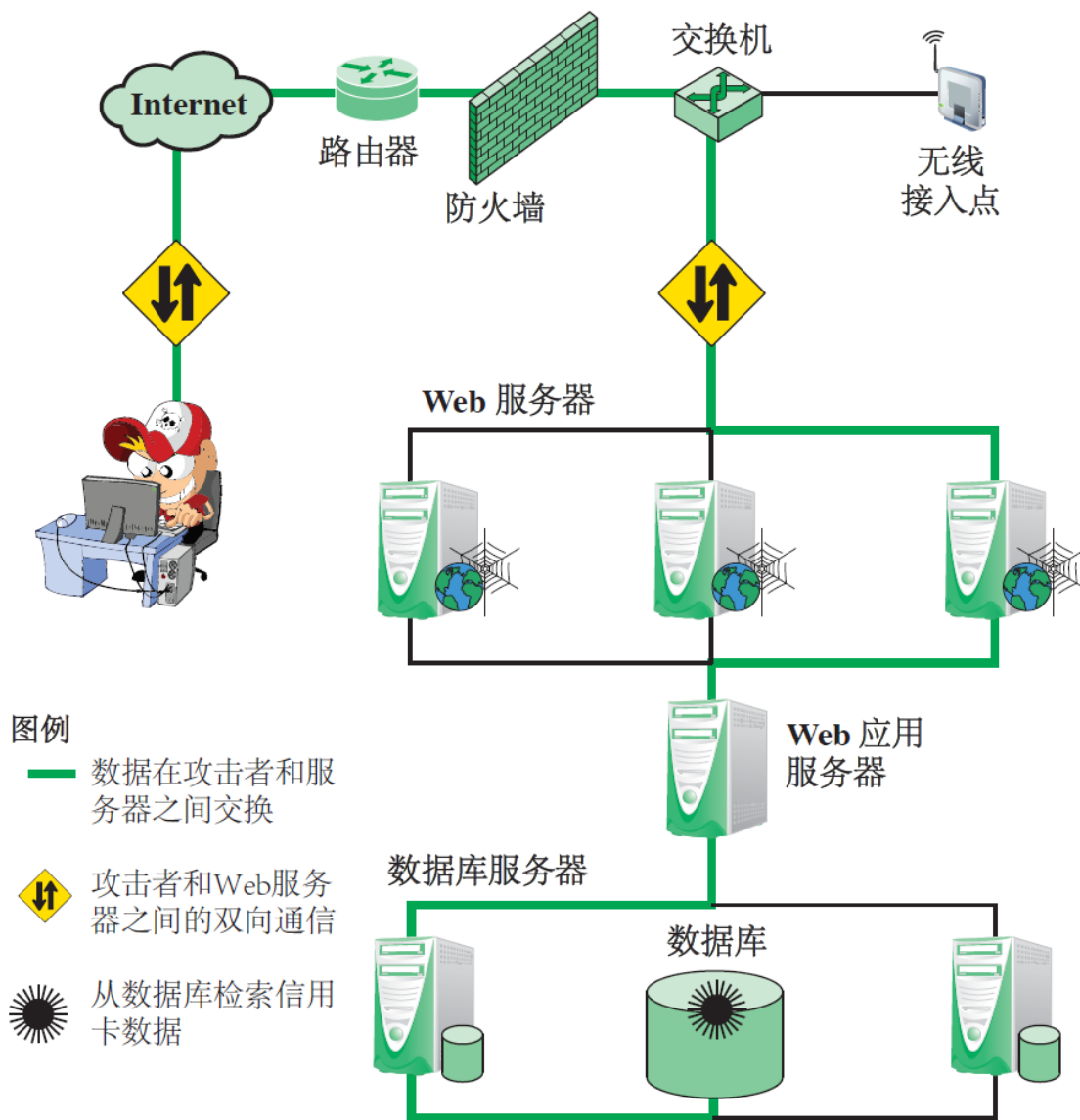
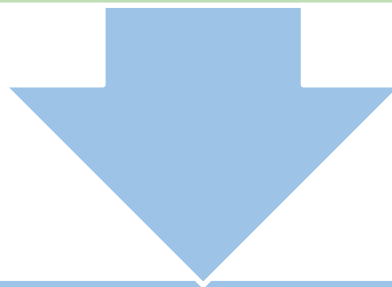


图 5.5 典型 SQL 注入攻击

注入技术

SQLi攻击的方法通常是在SQL语句中提前终止文本串，随后附加新的命令。

因为插入的命令在其被执行前可能含有额外附加的字符串，攻击者利用注释符“--”来终止注入的字符串。



这样,后面的文本在执行时就被忽略了。

SQLi 攻击途径和类型

用户输入

- 采用这一方式的攻击者，通过精心构造用户输入来注入SQL命令。

服务器变量

- 服务器变量是包含HTTP头部、网络协议头部、环境变量等数据的变量集合。

二阶注入

- 在二阶注入中，恶意用户可以利用系统或数据库中已存在的数据来触发一个SQL注入攻击，因此当这种攻击出现时，引发攻击的输入并不来自于用户，而是来自于系统自身。

Cookies

- 当客户端返回到 Web 应用时，cookie 可以用来恢复客户端的状态信息。

物理用户输入

- 除了Web请求外，还有其他可以用于SQL注入的用户输入。

带内攻击

- 使用同样的通信信道来完成SQL代码注入和结果返回。
- 这些返回的数据可以直接呈现在Web页面上。
- 包括:

重言式

这种形式的攻击是将代码注入一个或多个永真的条件表达式中。

行尾注释

在注入代码到特定字段之后，字段之后的合法代码会被注释标记为无效字段。

捎带查询

攻击者在预期查询之外添加额外的查询，使攻击行为与合法请求一同被执行。

推理攻击

- 没有实际的数据传输，但攻击者能够通过发送特定的请求和观察网站或数据库服务器的响应行为来重新构造信息。
- 包括：
 - 非法/逻辑错误查询
 - 攻击者将关于Web应用程序后台数据库的类型和结构等重要信息收集起来。
 - 这种方式一般作为其他攻击的初步信息收集步骤。
 - 盲 SQL 注入
 - 盲SQL注入允许攻击者推测数据库系统中的数据，即使系统足够安全,也不会将错误信息展示给攻击者。

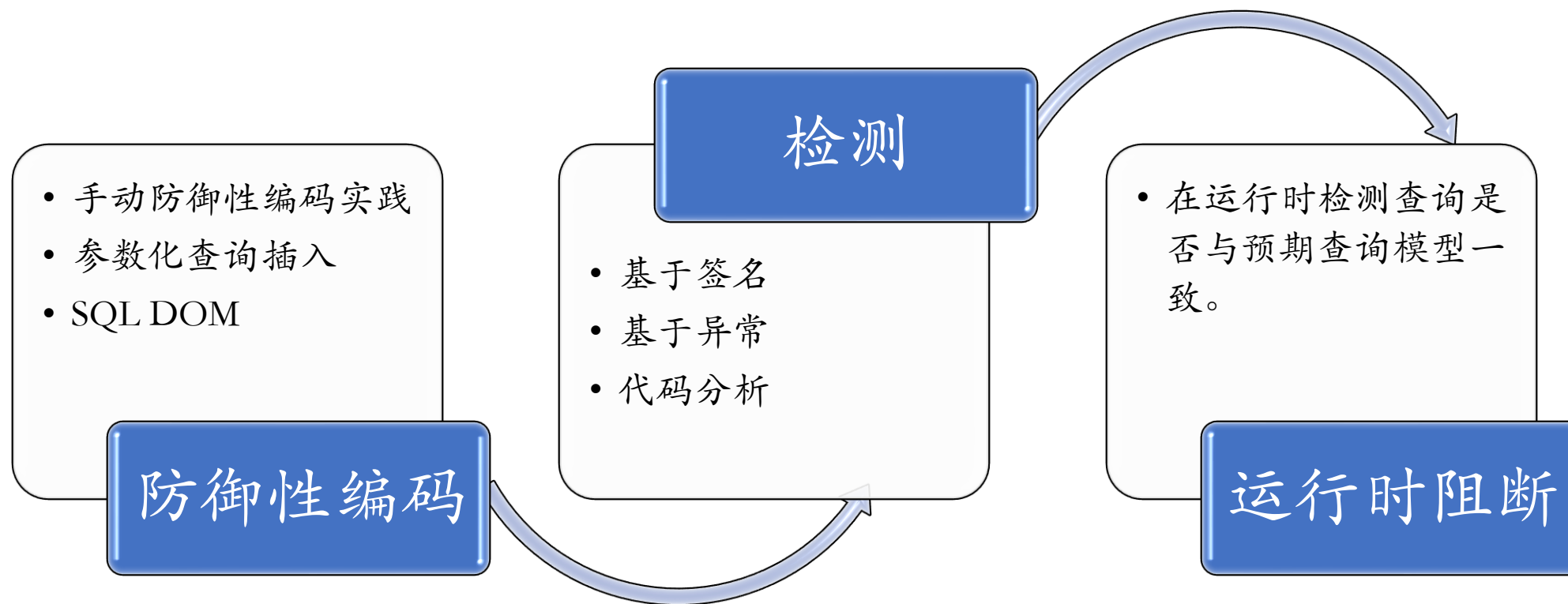


带外攻击

- 检索数据使用不同的通信信道。
- 这一方式可用于信息检索受限制但数据库服务器带外连接不严格的情况。

SQLi 应对措施

- 措施可分为3类:



第五章 数据库与云安全

- 5.1 数据库安全需求
- 5.2 数据库管理系统
- 5.3 关系数据库
- 5.4 SQL 注入攻击
- 5.5 数据库访问控制
- 5.6 推理
- 5.7 数据库加密
- 5.8 数据中心安全



数据库访问控制

- 数据库访问控制系统确定：
 - 用户是否有权限访问整个数据库
 - 用户有哪些访问权力（比如：创建，插入，删除，更新，读写）
- 可以支持不同的管理策略：
 - 集中管理
 - 基于所有权的管理
 - 分散管理



基于 SQL 的访问定义

- 提供了用于管理访问权的两个命令:
 - Grant
 - 这个命令可以用来授予一个或多个访问权或者为用户分配角色。
 - Revoke
 - 回收访问权
- 典型的访问权列表如下:
 - Select
 - Insert
 - Update
 - Delete
 - References

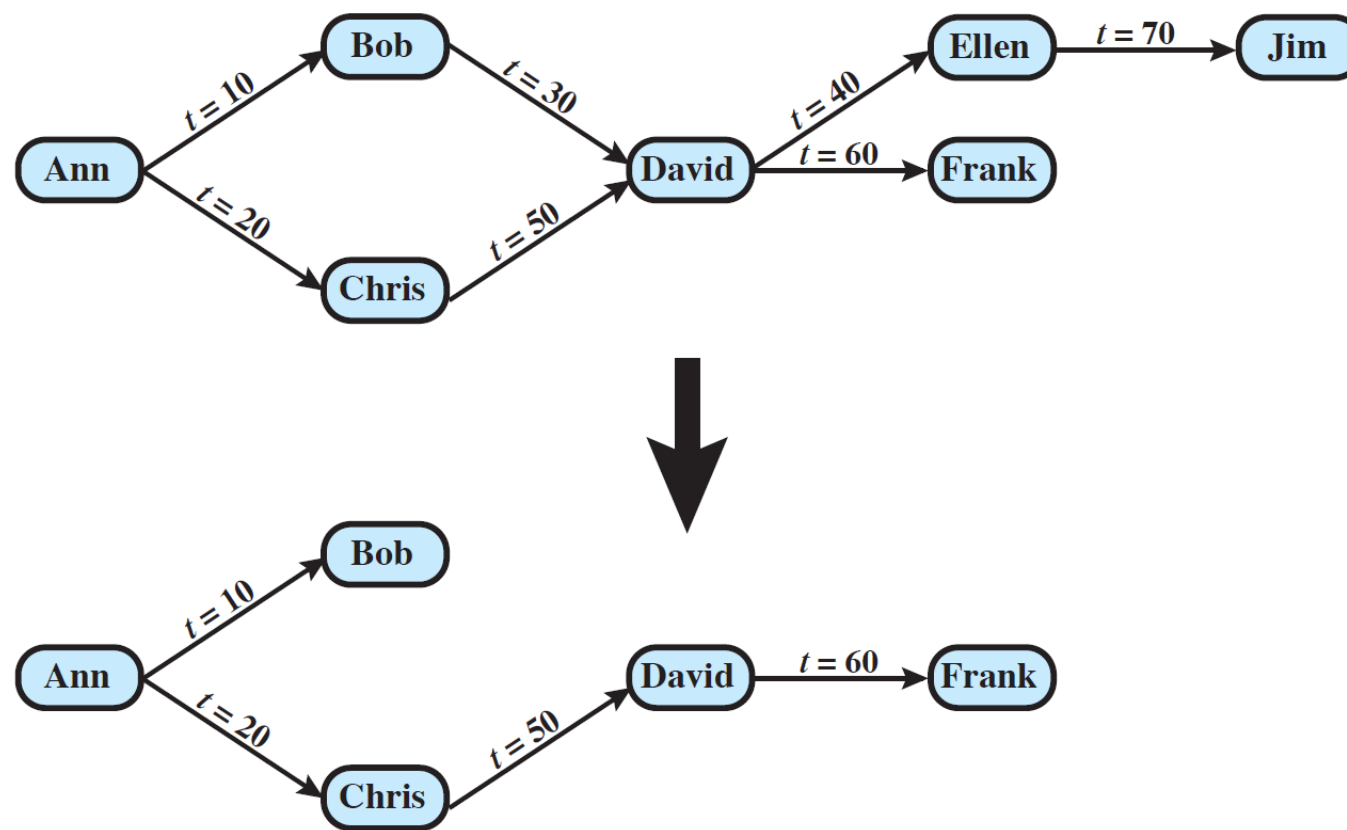


图 5.6 Bob 回收 David 的权限

基于角色的访问控制(RBAC)

- RBAC提供了一种既能减轻管理员负担又能提高安全性的手段。
- 数据库的RBAC机制应该提供以下能力：
 - 创建和删除角色
 - 定义角色的许可
 - 分配和取消用户到角色的分配
- 数据库用户分为三大类：

应用程序属主

- 拥有数据库对象并将其作为应用程序一部分的终端用户。

应用程序属主外的中断用户

- 不拥有任何数据库对象但可通过一个应用程序操作数据库对象的终端用户。

管理员

- 对数据库的整体或者部分负有管理职责的用户。



表 5-2 Microsoft SQL Server 中的固定角色

	角 色	许 可
固定 服务器 角色	sysadmin	可以执行 SQL Server 中的任何活动，对所有数据库功能具有完全控制
	serveradmin	可以设置服务器范围的配置选项，关闭服务器
	setupadmin	可以管理链接服务器和启动过程
	securityadmin	可以管理登录和 CREATE DATABASE 权限，还可以读取错误日志和修改口令
	processadmin	可以管理在 SQL Server 中运行的进程
	dbcreator	可以创建、修改和删除数据库
	diskadmin	可以管理磁盘文件
	bulkadmin	可以执行 BULK INSERT 语句
固定 数据库 角色	db_owner	具有数据库的所有权限
	db_accessadmin	可以添加、删除用户 ID
	db_datareader	可以选择数据库中任何用户表的所有数据
	db_datawriter	可以修改数据库中任何用户表的任何数据
	db_ddladmin	可以执行所有的数据定义语言（DDL）语句
	db_securityadmin	可以管理所有的许可、对象所有权、角色和角色成员资格
	db_backupopoeator	可以执行 DBCC、CHECKPOINT 和 BACKUP 语句
	db_denydatareader	没有在数据库中选择数据的权限
	db_denydatawriter	没有在数据库中修改数据的权限

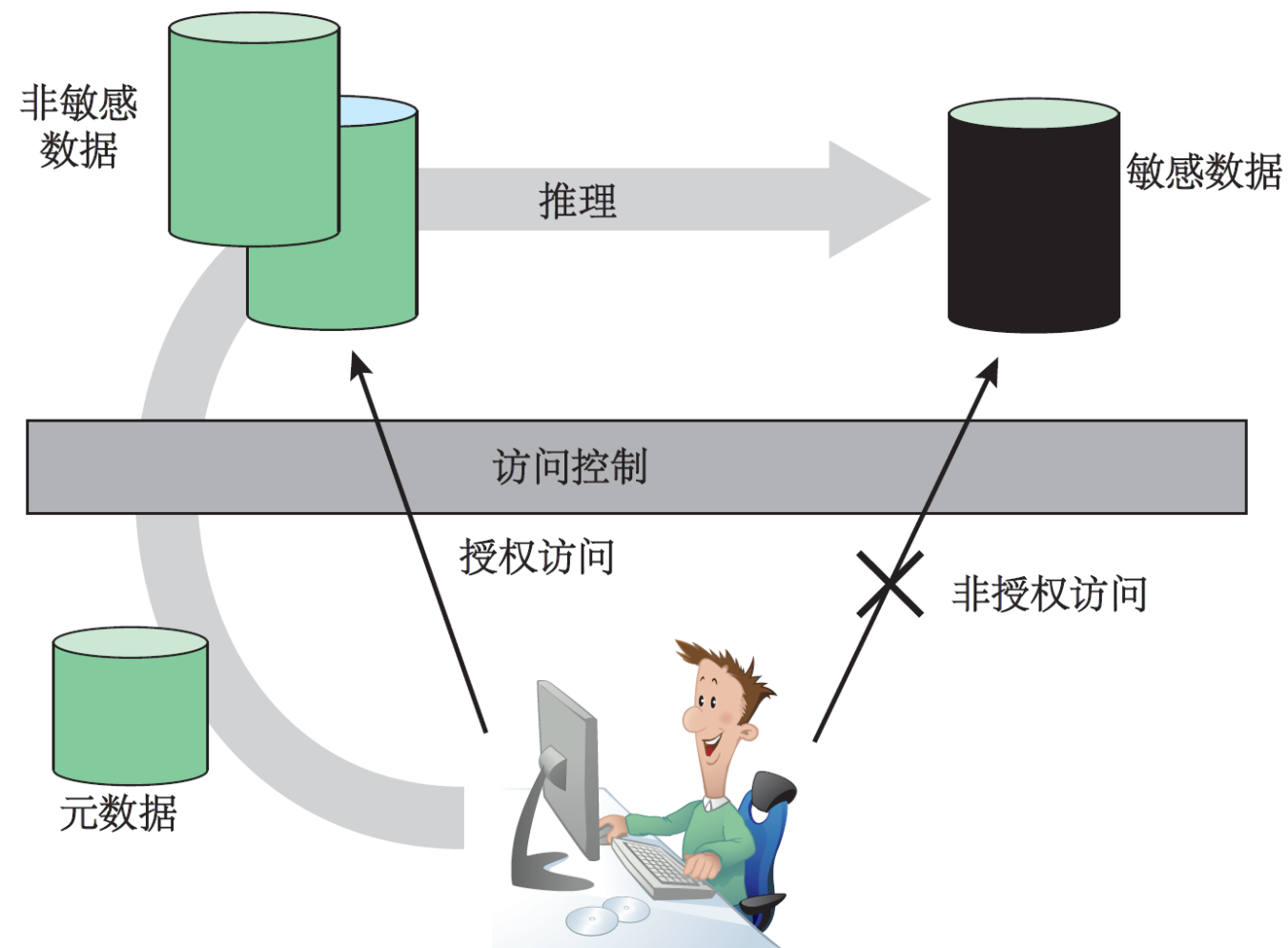


图 5.7 经由推理通道的间接信息访问

Item	Availability	Cost (\$)	Department
Shelf support	in-store/online	7.99	hardware
Lid support	online only	5.49	hardware
Decorative chain	in-store/online	104.99	hardware
Cake pan	online only	12.99	housewares
Shower/tub cleaner	in-store/online	11.99	housewares
Rolling pin	in-store/online	10.99	housewares

a) Inventory表

Availability	Cost (\$)
in-store/online	7.99
online only	5.49
in-store/online	104.99

Item	Department
Shelf support	hardware
Lid support	hardware
Decorative chain	hardware

b) 两个视图

Item	Availability	Cost (\$)	Department
Shelf support	in-store/online	7.99	hardware
Lid support	online only	5.49	hardware
Decorative chain	in-store/online	104.99	hardware

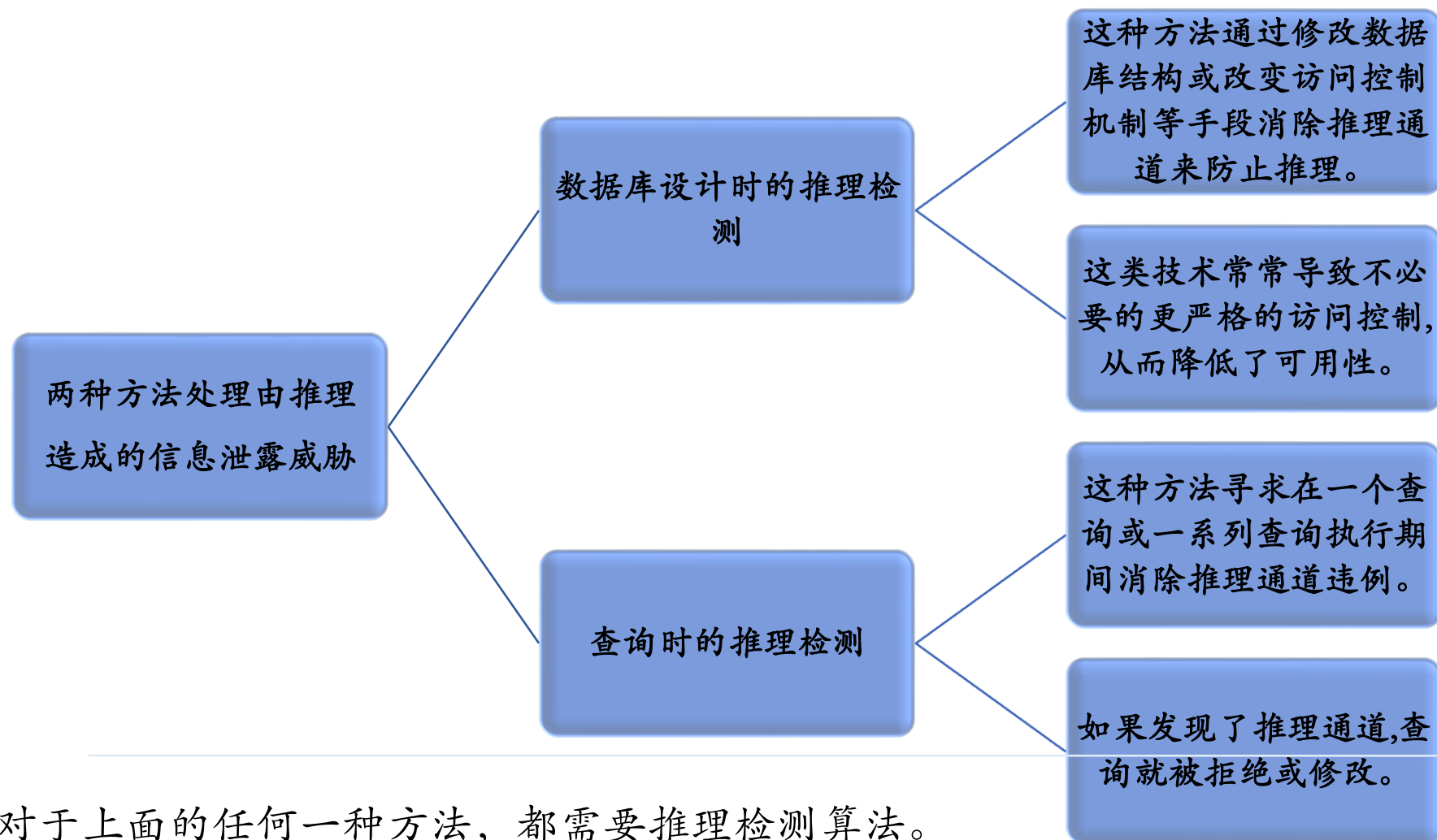
c) 从组合查询应答推导出的表

图 5-8 推理的实例

第五章 数据库与云安全

- 5.1 数据库安全需求
- 5.2 数据库管理系统
- 5.3 关系数据库
- 5.4 SQL 注入攻击
- 5.5 数据库访问控制
- 5.6 推理
- 5.7 数据库加密
- 5.8 数据中心安全

推理检测



- 对于上面的任何一种方法, 都需要推理检测算法。
- 在后面讨论的多级安全数据库和统计数据库, 在设计具体技术方面已经取得了一些进展。

第五章 系统与云安全

- 5.1 数据库安全需求
- 5.2 数据库管理系统
- 5.3 关系数据库
- 5.4 SQL 注入攻击
- 5.5 数据库访问控制
- 5.6 推理
- 5.7 数据库加密
- 5.8 数据中心安全



数据库加密

- 数据库对于任何组织来说都是最宝贵的信息源
 - 被多级安全保护
 - 包括防火墙、鉴别机制、通用访问控制系统和数据库访问控制系统。
 - 加密成为数据库安全的最后一道防线。
 - 加密可以在记录级、属性级或单个字段级运用到整个数据库
- 数据库加密在以下两个方面存在缺点:
 - 密钥管理
 - 授权用户必须能够访问其被允许访问的数据的解密密钥。
 - 不灵活
 - 当数据库的部分或全部被加密时，执行记录搜索变得更为困难。

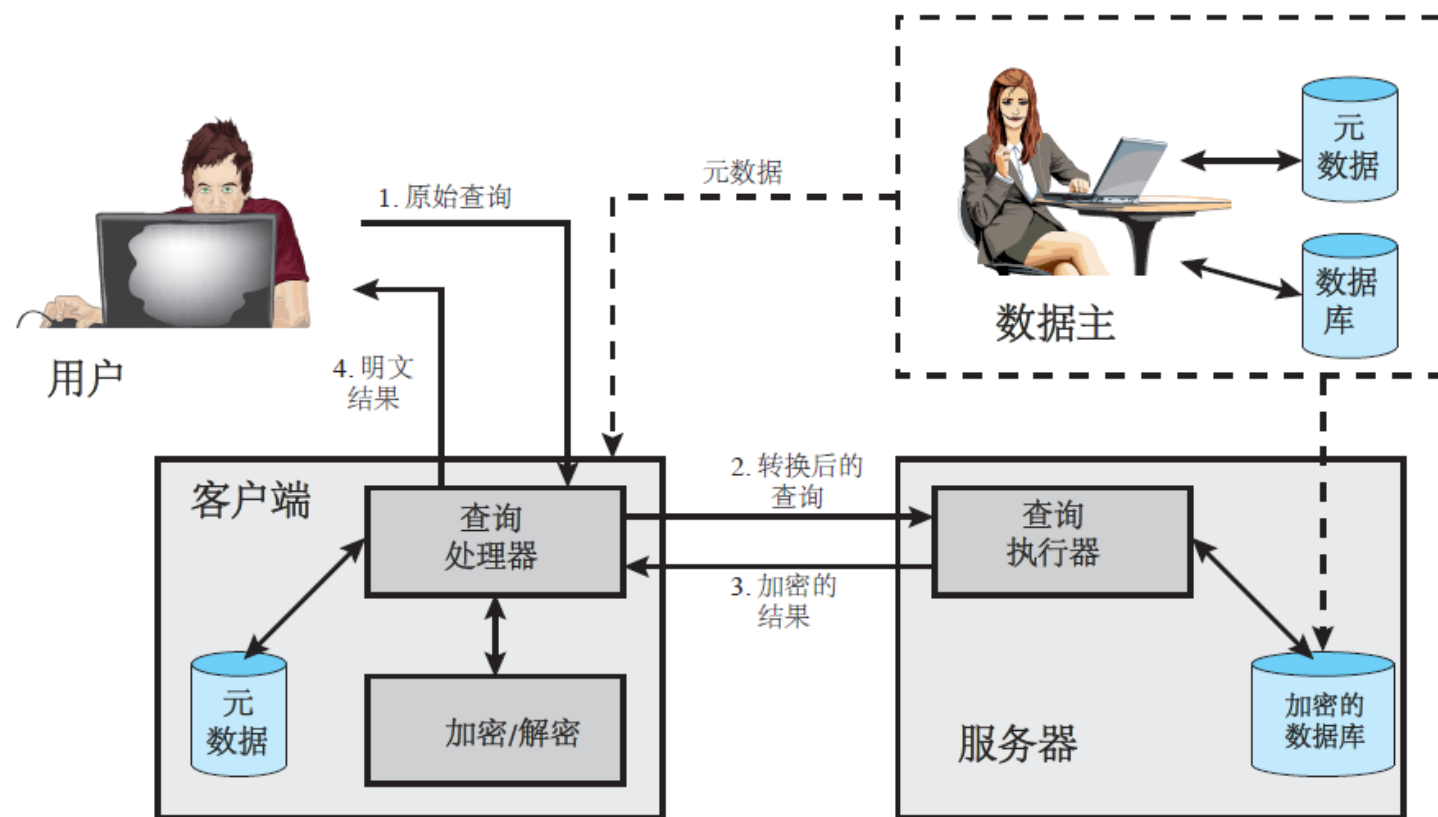


图 5.9 一种数据加密方案

$E(k, B_1)$	I_{11}	$\cdot \cdot \cdot$	I_{1j}	$\cdot \cdot \cdot$	I_{1M}
$\cdot$	$\cdot$		$\cdot$		$\cdot$
$\cdot$	$\cdot$		$\cdot$		$\cdot$
$\cdot$	$\cdot$		$\cdot$		$\cdot$
$E(k, B_i)$	I_{i1}	$\cdot \cdot \cdot$	I_{ij}	$\cdot \cdot \cdot$	I_{iM}
$\cdot$	$\cdot$		$\cdot$		$\cdot$
$\cdot$	$\cdot$		$\cdot$		$\cdot$
$\cdot$	$\cdot$		$\cdot$		$\cdot$
$E(k, B_N)$	I_{N1}	$\cdot \cdot \cdot$	I_{Nj}	$\cdot \cdot \cdot$	I_{NM}

$$B_i = (x_{i1} \parallel x_{i2} \parallel \dots \parallel x_{iM})$$

图 5.10 图 5.3 中数据库的加密方案

表 5-3 加密数据库举例

a) Employee 表

eid	ename	salary	addr	did
23	Tom	70K	Maple	45
860	Mary	60K	Main	83
320	John	50K	River	50
875	Jerry	55K	Hopewell	92

b) 具有索引的加密的 Employee 表

$E(k, B)$	$I(eid)$	$I(ename)$	$I(salary)$	$I(addr)$	$I(did)$
1100110011001011...	1	10	3	7	4
0111000111001010...	5	7	2	7	8
1100010010001101...	2	5	1	9	5
0011010011111101...	5	5	2	4	9

第五章 数据库与云安全

- 5.1 数据库安全需求
- 5.2 数据库管理系统
- 5.3 关系数据库
- 5.4 SQL 注入攻击
- 5.5 数据库访问控制
- 5.6 推理
- 5.7 数据库加密
- 5.8 数据中心安全



数据中心安全

- 数据中心:
 - 是一个容纳了大量服务器、存储设备、网络交换机和装备的企业设施。
 - 一个数据中心内的服务器和存储设备数量可能会达到数万。
 - 一个数据中心通常包括冗余或备份电源、冗余网络连接、环境控制一个数据中心可以占据一整间房间、一个或多个楼层,甚至整个建筑物。
- 使用大型数据中心的例子包括:
 - 云服务提供者
 - 搜索引擎
 - 大型科学研究设施
 - 大型企业的IT设施

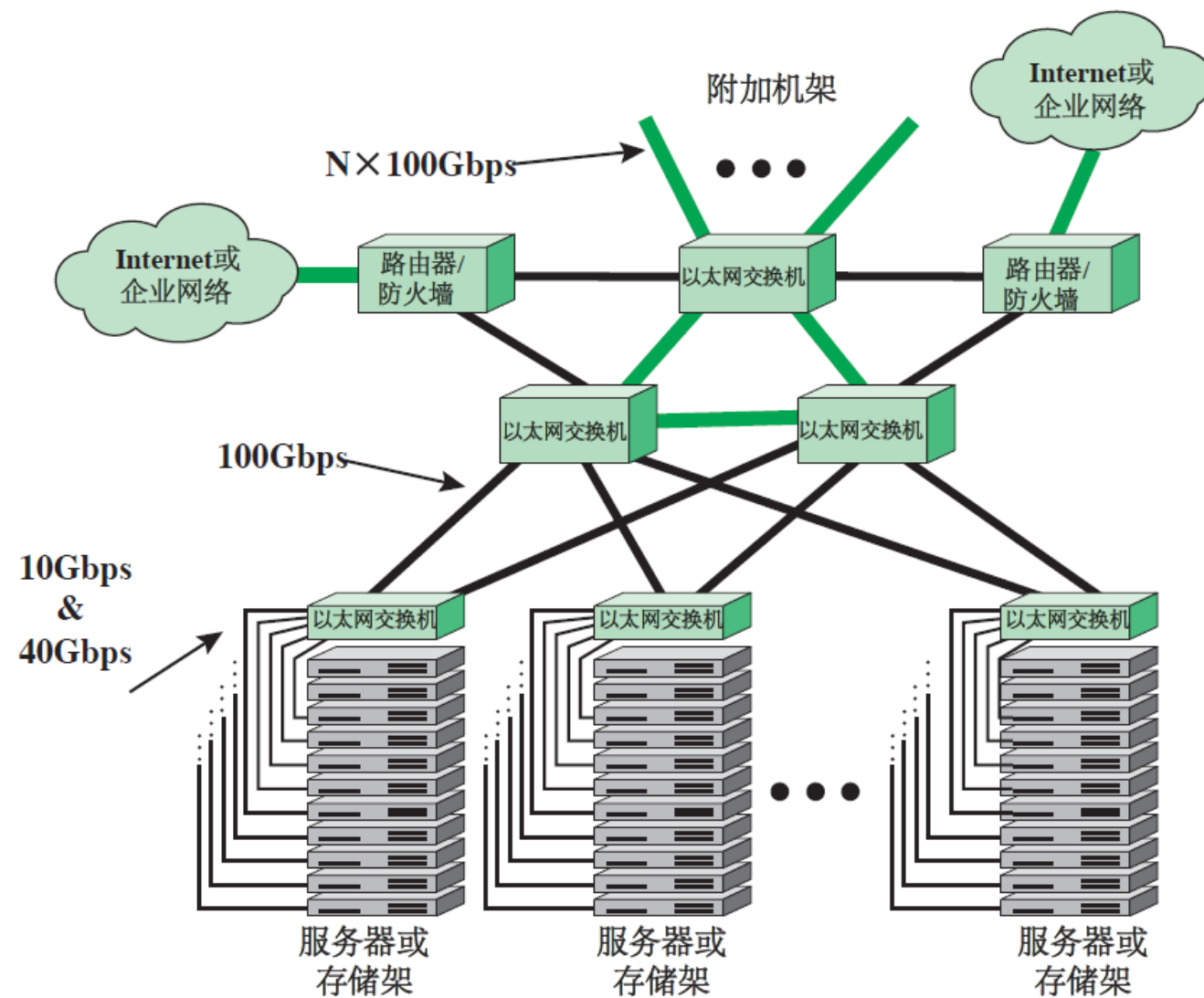


图 5.11 关键数据中心要素

数据安全	加密，口令策略，安全ID，数据保护 (ISO 27002)，数据脱敏，数据保留，等等
网络安全	服务器，反病毒，入侵检测/保护，认证，等等
物理安全	监控，双门互锁，双/三因素认证，安全区域， ISO 27001/27002 ，等等
场地安全	阻碍，冗余设施，景观，缓冲区域，防护栏，入口点，等等

图 5.12 数据中心安全模型



TIA-492

- 电信工业协会 (TIA)
- TIA-492 (数据中心电信基础设施标准) 规定了数据中心电信基础设施的最低要求，包括以下主体：
 - 网络架构
 - 电气设计
 - 文件存储、备份及归档
 - 系统冗余
 - 网络访问控制和安全
 - 数据库管理
 - 虚拟主机
 - 应用托管
 - 内容分发
 - 环境控制
 - 防止物理灾害（火灾、洪水和风暴）
 - 电源管理

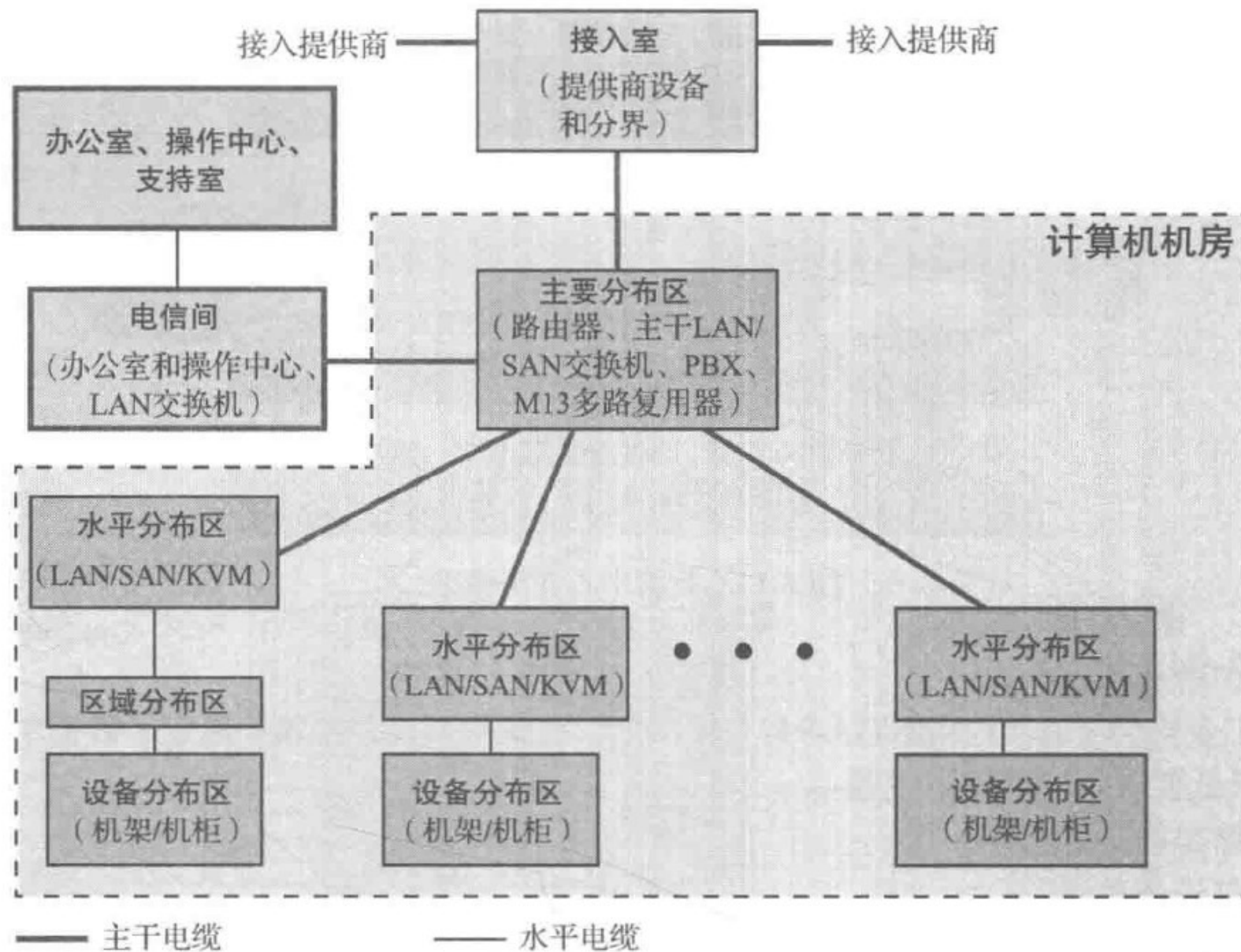


图 5-13 TIA-942 合规的数据中心显示的关键功能区域

表 5-4 TIA-942 中定义的数据中心等级

等 级	系统设计	可用性 / 每年停机时间
1	● 容易受到计划和非计划活动的干扰 ● 为电源和制冷分配单一路径，无冗余组件 ● 可能会或可能不会有活动地板、UPS 或发电机 ● 需要 3 个月的时间来实施 ● 必须完全关闭以执行预防性维护	99.671%/28.8 小时
2	● 不易受到计划内和计划外活动的干扰 ● 为电源和制冷分配单一路径，包含冗余组件 ● 包含活动地板、UPS 和发电机 ● 需要 3 到 6 个月实施 ● 电力和基础设施的其他部分的维护需要关机进行	99.741%/22.0 小时
3	● 在不中断计算机硬件操作的情况下启用计划的活动，但未计划的事件仍会导致中断 ● 多电源和制冷分配路径，但是只有一个路径有效，包含冗余组件 ● 需要 15 到 20 个月实施 ● 包含活动地板、充足的生产和分配能力，以便在一个路径上承载负载，同时在另一个路径上执行维护	99.982%/1.6 小时
4	● 计划的活动不会中断关键负载，并且数据中心可以承受至少一个最严重的计划外事件而不会对关键负载产生影响 ● 多有效电源和制冷分配路径，包含冗余组件 ● 需要 15 至 20 个月实施	99.995%/0.4 小时

本章小结

- 5.1 数据库安全需求
- 5.2 数据库管理系统
- 5.3 关系数据库
 - 5.3.1 关系数据库系统要素
 - 5.3.2 结构化查询语言
- 5.4 SQL 注入攻击
 - 5.4.1 一种典型的SQLi 攻击
 - 5.4.2 注入技术
 - 5.4.3 SQLi 攻击途径和类别
 - 5.4.4 SQLi 应对措施
- 5.5 数据库访问控制
 - 5.5.1 基于SQL的访问定义
 - 5.5.2 级联授权
 - 5.5.3 基于角色的访问控制
- 5.6 推理
- 5.7 数据库加密
- 5.8 数据中心安全
 - 5.8.1 数据中心要素
 - 5.8.2 数据中心安全注意事项
 - 5.8.3 TIA-492

参考文献

- 文献5.1 A Classification of SQL Injection Attacks and Countermeasures
- 文献5.2 SQLrand: Preventing SQL Injection Attacks
- 文献5.3 Verifiable Computation over Large Database with Incremental Updates
- 文献5.4 Distributed Database Management Techniques for Wireless Sensor Networks

参考文献

参考文献如图所示：

A Classification of SQL Injection Attacks and Countermeasures

William G.J. Halfond, Jeremy Viegas, and Alessandro Orso
College of Computing
Georgia Institute of Technology
{whalfond|jeremyv|orso}@cc.gatech.edu

Verifiable Computation over Large Database with Incremental Updates

Xiaofeng Chen^{1,4}, Jin Li^{2,4}, Jian Weng³, Jianfeng Ma¹, and Wenjing Lou⁴

¹ State Key Laboratory of Integrated Service Networks (ISN),
Xidian University, Xi'an 710071, P.R. China

xfchen@xidian.edu.cn, jfma@mail.xidian.edu.cn

² School of Computer Science and Educational Software,
Guangzhou University, Guangzhou 510006, P.R. China
jinli71@gmail.com

³ Department of Computer Science,
Jinan University, Guangzhou 510632, P.R. China
cryptjweng@gmail.com

⁴ Department of Computer Science,
Virginia Polytechnic Institute and State University, USA
wj1ou@vt.edu

SQLrand: Preventing SQL Injection Attacks

Stephen W. Boyd and Angelos D. Keromytis

Department of Computer Science
Columbia University
{swb48,angelos}@cs.columbia.edu

Abstract. We present a practical protection mechanism against SQL injection attacks. Such attacks target databases that are accessible through a web front-end, and take advantage of flaws in the input validation logic of Web components such as CGI scripts. We apply the concept of instruction-set randomization to SQL, creating instances of the language that are unpredictable to the attacker. Queries injected by the attacker will be caught and terminated by the database parser. We show how to use this technique with the MySQL database using an intermediary proxy that translates the random SQL to its standard language. Our mechanism imposes negligible performance overhead to query processing and can be easily retrofitted to existing systems.

Distributed Database Management Techniques for Wireless Sensor Networks

Ousmane Diallo, Joel J. P. C. Rodrigues, *SeniorMember, IEEE*,
Mbaye Sene, and Jaime Lloret, *SeniorMember, IEEE*



感谢聆听!
huangke@uestc.edu.cn